

CareLite Healthcare Learning Platform

Functional Requirements Document

Functional requirements for the CareLite MVP services, roles, APIs, events, and acceptance criteria.

Field	Value
Document Type	FRD
Version	0.1
Date	2026-05-15
Status	Draft for learning and implementation planning
Primary Stack	Java 21, Spring Boot 3.3.x, Spring Cloud 2023.0.x, Maven 15-module monorepo, Spring Cloud Gateway, OpenFeign, Amazon MSK/Kafka, MongoDB Atlas, AWS EKS, Cognito, S3, WAF, Shield, Jenkins, Argo CD

Document Control

Item	Details
Owner	CareLite learning project team
Audience	Developer, DevOps engineer, solution architect, product owner
Purpose	Guide a small healthcare platform that teaches production microservice patterns.
Scope Level	MVP plus platform learning patterns

1. Functional Overview

This FRD describes the functional requirements for the CareLite MVP. Requirements are grouped by service and user role. Each major workflow includes API behavior, validation, idempotency, events, and acceptance criteria.

1.1 Verified Stack Baseline

Category	Functional Baseline
Languages and frameworks	Java 21 virtual threads and records; Spring Boot 3.3.x; Spring Cloud 2023.0.x; Maven multi-module with 15 modules.
Data	Amazon RDS PostgreSQL per-tenant schemas; MongoDB Atlas event store and CQRS read models; ElastiCache Redis; Amazon S3.
Messaging	Amazon MSK/Kafka domain.events with 48 partitions; Apache Avro; Confluent Schema Registry; Transactional Outbox.
Identity and security	AWS Cognito OAuth2 with custom JWT claims; Spring Security RBAC; IAM/IRSA; WAF; Shield; Falco; Trivy.
Patterns	Event Sourcing, CQRS, Saga orchestration, Outbox, Idempotency, per-schema multi-tenancy, DDD bounded contexts.
Observability	Prometheus, Grafana, Loki, Fluent Bit, OpenTelemetry, Tempo, Alertmanager, Grafana Faro.
Quality and delivery	Spring Batch, iText 8, Apache POI, EventArchivalJob, Argo CD, Google Jib, SonarQube, Flyway, Testcontainers, ArchUnit, WireMock.

2. Roles and Permissions

Capability	Super Admin	Clinic Admin	Doctor	Receptionist	Patient
Onboard clinic	Yes	No	No	No	No
Manage clinic staff	Support	Yes	No	No	No
Register patient	No	Yes	No	Yes	Self optional
Book appointment	No	Yes	View	Yes	Request
Write doctor note	No	No	Yes	No	No
Create invoice	No	Yes	No	Yes	No
View own documents	No	No	No	No	Yes

Capability	Super Admin	Clinic Admin	Doctor	Receptionist	Patient
View tenant audit	Cross-tenant	Own tenant	Own actions	Own actions	Own records

3. Tenant Onboarding

3.1 Create Tenant

Endpoint: POST /api/v1/tenants/onboard. Required role: SUPER_ADMIN. Idempotency-Key is required.

```
{
  "clinicName": "Apollo Care Clinic",
  "slug": "apollo",
  "adminEmail": "admin@apollo.example",
  "adminName": "Clinic Admin",
  "timezone": "Asia/Kolkata"
}
```

- Validate slug format, uniqueness, email format, and idempotency key.
- Create master.tenants row with status PROVISIONING.
- Create schema clinic_apollo and run tenant Flyway migrations.
- Create S3 prefix tenants/clinic_apollo/.
- Create Cognito groups and first Clinic Admin user.
- Mark tenant ACTIVE and emit TENANT_ONBOARDED.

3.2 Tenant Lifecycle

Endpoint	Description	Event
GET /api/v1/tenants	List tenants with status and plan.	None
GET /api/v1/tenants/{slug}	Fetch tenant detail.	None
POST /api/v1/tenants/{id}/retry	Retry failed provisioning step.	TENANT_PROVISIONING_RETRIED
POST /api/v1/tenants/{id}/suspend	Disable tenant access.	TENANT_SUSPENDED
POST /api/v1/tenants/{id}/activate	Restore tenant access.	TENANT_ACTIVATED

4. Identity and OAuth2

- Use Cognito Hosted UI with Authorization Code plus PKCE.
- Gateway validates JWT issuer, audience, expiration, and signature.
- JWT claims must include tenant_id, roles, email, and cognito sub.
- Gateway injects X-Tenant-ID, X-Actor-ID, X-Roles, and X-Correlation-ID into downstream calls.
- Services enforce method-level RBAC based on roles.

5. Gateway, Rate Limit, and Resilience Requirements

Requirement	Functional Behavior
Tenant gateway filter	Resolve tenant from subdomain or token claim, validate ACTIVE tenant, write X-Tenant-ID header.
OAuth2 resource server	Reject missing, expired, invalid, or wrong-audience Cognito JWTs before routing.
Route rate limit	Apply Redis-backed Spring Cloud Gateway rate limits per route, tenant, role, and client IP.
Edge rate limit	AWS WAF rate-based rules protect CloudFront and ALB. Route 53 only routes DNS and health failover.
Circuit breaker	Gateway routes use circuit breaker filters for downstream outages and return controlled 503 responses.
Feign resilience	Service-to-service clients use OpenFeign with timeout, retry, circuit breaker, and fallback rules.

6. Clinic Service Requirements

Area	Endpoints	Functional Rules
Patients	POST/GET/PUT /api/v1/patients	Create patient, check duplicate email/mobile per tenant, emit PATIENT_REGISTERED.
Doctors	POST/GET/PUT /api/v1/doctors	Create doctor profile, link to Cognito user, set specialization and active status.
Appointments	POST/GET/PUT /api/v1/appointments	Book by doctor, patient, date/time; prevent overlapping confirmed slots.
Doctor Notes	POST /api/v1/appointments/{id}/notes	Doctor can add note after appointment starts; emit VISIT_NOTE_CREATED.
Documents	POST /api/v1/documents/upload-url	Return pre-signed S3 upload URL under tenant prefix.

7. Billing Service Requirements

- Create invoice automatically when appointment is confirmed if clinic config enables billing.
- Support manual invoice creation for consultation fees.
- Track payment status: PENDING, PAID, FAILED, WAIVED, REFUNDED.
- Use Feign client calls to clinic-service only for read-side validation where an event-driven copy is not yet available.
- Wrap Feign calls in Resilience4j circuit breakers and return safe business errors when dependencies are unavailable.
- Publish INVOICE_CREATED and PAYMENT_STATUS_UPDATED events.
- Suppress external side effects when processing replayed events.

8. Audit and Event Requirements

Endpoint	Purpose
GET /api/v1/audit/events	List tenant audit events with filters: type, actor, aggregate, date range.
GET /api/v1/audit/events/{eventId}	View event detail.

Endpoint	Purpose
GET /api/v1/audit/aggregates/{type}/{id}/history	View aggregate history.
POST /api/v1/audit/events/{eventId}/replay	Replay safe event types for learning.
GET /api/v1/audit/replay/{jobId}/status	Check replay progress.

- audit-event-service stores canonical events in MongoDB collection event_store.
- Indexes must support tenant_id plus occurred_at, tenant_id plus aggregate, and tenant_id plus actor queries.
- MongoDB Atlas also stores CQRS read models for audit dashboards, appointment timelines, and billing summaries.
- Kafka event payloads use Apache Avro and are validated through Confluent Schema Registry.
- The domain.events topic starts with 48 partitions and is partitioned by tenant_id plus aggregate_id.
- Events are append-only from application perspective; replay creates replay records and new audit entries rather than mutating originals.
- Cold audit exports can be written to S3 for long-term retention learning.

9. Idempotency Rules

- POST create endpoints require Idempotency-Key unless explicitly read-only.
- Idempotency scope is tenant_id plus endpoint plus key.
- Same request payload and key returns the original response.
- Different payload with same key returns 409 IDEMPOTENCY_CONFLICT.
- Provisioning retry uses the original tenant onboarding record rather than creating a new tenant.

10. Events

Event	Producer	Consumer
TENANT_ONBOARDED	tenant-service	audit-event-service
PATIENT_REGISTERED	clinic-service	audit-event-service
APPOINTMENT_BOOKED	clinic-service	billing-service, audit-event-service
APPOINTMENT_CANCELLED	clinic-service	billing-service, audit-event-service
VISIT_NOTE_CREATED	clinic-service	audit-event-service
INVOICE_CREATED	billing-service	audit-event-service
PAYMENT_STATUS_UPDATED	billing-service	audit-event-service

11. DevOps, HA, and Scalability Requirements

Area	Requirement
Ingress	Use AWS Load Balancer Controller ingress with ACM-managed TLS and HTTPS redirect.

Area	Requirement
Secrets	Use AWS Secrets Manager for DB credentials, Cognito settings, Kafka credentials, and MongoDB URI.
Security	Use AWS WAF and Shield at the edge, Falco for runtime detection, and Trivy for CVE scanning.
Kubernetes HA	Each stateless service has at least two replicas, readiness/liveness probes, rolling updates, and PodDisruptionBudget.
Autoscaling	Use HPA for CPU/memory/request metrics and optionally KEDA for Kafka consumer lag.
Jenkins	Pipeline must test, run SonarQube, scan with Trivy, build images with Google Jib, push to ECR, and update Helm values.
Argo CD	Argo CD owns deployment sync, drift detection, rollback, and environment promotion from Git.

12. Batch and Document Requirements

Job or Feature	Requirement
PatientBulkImportJob	Spring Batch job reads Excel through Apache POI and creates patients idempotently.
AppointmentReminderJob	Spring Batch job emits reminder commands without duplicate notifications.
InvoiceExportJob	Spring Batch job exports invoice summaries to Excel using Apache POI.
ReplayJob	Spring Batch job replays safe event ranges through Kafka with replay metadata.
EventArchivalJob	Nightly Spring Batch job exports MongoDB event-store records to S3 Avro cold archive.
PDF documents	iText 8 generates prescriptions, invoices, and appointment summaries.

13. Java Design Pattern Learning Requirements

Pattern	Where to Practice
Chain of Responsibility	Gateway filters: correlation, tenant, auth, rate limit enrichment.
Strategy	Tenant provisioning steps and document storage policy.
Factory	Domain event creation and Feign client fallback response builders.
Template Method	Reusable onboarding workflow with overridable provisioning steps.
Adapter	Cognito, S3, MongoDB, and payment-provider integration ports.
Saga	Tenant onboarding and appointment-to-invoice workflow.
Observer	Outbox events consumed by billing and audit services.

14. Acceptance Criteria

- A new tenant can be onboarded and used without manually creating a database schema.
- A Cognito-authenticated Clinic Admin can create a patient in their own tenant only.
- Two tenants can create patients with the same email without data collision if business policy allows tenant-local uniqueness.

- Appointment booking emits an outbox event and audit entry.
- Gateway returns 429 when route or tenant rate limits are exceeded.
- A forced clinic-service outage opens billing-service circuit breaker and exposes breaker metrics.
- Audit events persist to MongoDB and are queryable by tenant, actor, aggregate, and date range.
- Jenkins can build, test, scan, push an image to ECR, and update deployment manifests.
- Argo CD can sync the updated manifests into EKS.